

TeleCare Connect - Software Requirements Specification

Document Control

- **Product:** TeleCare Connect Telemedicine Platform
- **Version:** 1.0
- **Date:** October 22, 2025
- **Classification:** Internal Development
- **Author:** TeleCare Engineering Team

System Overview

TeleCare Connect is a direct-to-consumer telemedicine platform enabling patients to connect with licensed healthcare providers via secure video consultations. The platform serves patients seeking primary care services, urgent care consultations, and prescription management across multiple states. The system provides an integrated solution for scheduling, video consultations, symptom assessment, and e-prescribing capabilities.

Target Users

- **Patients:** Adults 18+ seeking remote medical consultations
- **Healthcare Providers:** Licensed physicians (MD/DO), nurse practitioners (NP), physician assistants (PA)
- **Administrative Staff:** Customer support, billing, compliance monitoring

Key Features

- High-definition video consultations
- Patient registration and profile management
- Appointment scheduling with calendar integration
- AI-powered symptom assessment questionnaire
- Electronic prescribing integration
- Secure messaging between patients and providers
- Insurance verification and payment processing
- Electronic health record (EHR) integration

Regulatory Context

Applicable Regulations

- **HIPAA Privacy Rule** (45 CFR Part 164 Subpart E): Governs protected health information (PHI) privacy
- **HIPAA Security Rule** (45 CFR Part 164 Subpart C): Establishes security standards for ePHI
- **State Medical Licensing Laws:** Physicians must be licensed in the state where the patient is located
- **State Telemedicine Laws:** Varying requirements for telemedicine practice standards
- **FDA Clinical Decision Support:** Oversight of software providing diagnostic recommendations

Compliance Standards

- SOC 2 Type II certification for data security
- HITRUST CSF Framework compliance
- State telemedicine parity laws compliance

Functional Requirements

REQ-AUTH-001: User Authentication

Priority: Critical

Description: The system shall provide secure user authentication for patients and providers. Users shall authenticate using email address and password credentials.

Acceptance Criteria:

1. Password complexity: minimum 8 characters, one uppercase, one number
2. Account lockout after 5 failed attempts
3. Password reset via email verification **Compliance Standards:** HIPAA §164.308(a)(3)(i)

REQ-AUTH-002: Session Management

Priority: High

Description: The system shall manage active user sessions with appropriate security controls.

Acceptance Criteria:

1. User sessions shall persist for the duration of active use
2. Users shall remain logged in until they explicitly log out
3. Session cookies shall use secure flag **Compliance Standards:** HIPAA §164.312(a)(2)(iii)

REQ-VIDEO-001: Video Consultation Platform

Priority: Critical

Description: The system shall provide real-time video consultation capabilities between patients and providers using WebRTC technology.

Acceptance Criteria:

1. Support for 720p minimum video quality
2. Adaptive bitrate based on network conditions
3. Audio/video synchronization within 100ms
4. Screen sharing capability for providers
5. Recording capability for medical documentation **Compliance Standards:** HIPAA §164.312(a)(2)(iv)

REQ-SYMP-001: Symptom Assessment Tool

Priority: High

Description: The system shall provide an AI-powered symptom assessment questionnaire to help patients describe their medical concerns and receive preliminary guidance.

Acceptance Criteria:

1. Interactive questionnaire based on patient's chief complaint
2. Adaptive questioning based on patient responses
3. Generation of symptom summary report for provider review
4. Risk stratification indicating urgency level (low, medium, high)
5. Specific condition likelihood scores (e.g., "75% likelihood of strep throat")
6. Treatment recommendations when clinical certainty is high **Compliance Standards:** FDA Clinical Decision Support Guidance

REQ-PRESC-001: E-Prescribing

Priority: Critical

Description: The system shall integrate with pharmacy networks to enable electronic prescription transmission.

Acceptance Criteria:

1. NCPDP SCRIPT standard compliance for prescription messages

2. Integration with Surescripts network
3. Formulary checking and generic alternatives
4. Patient medication history retrieval
5. Prior authorization workflow support **Compliance Standards:** DEA EPCS requirements for controlled substances

REQ-SCHED-001: Appointment Scheduling

Priority: High

Description: Patients shall be able to browse provider availability and book appointments through the web and mobile applications.

Acceptance Criteria:

1. Real-time provider availability calendar
2. Filter by specialty, language, insurance acceptance
3. Same-day and next-day appointment options
4. Automated email and SMS reminders
5. Cancellation and rescheduling capability **Compliance Standards:** N/A - Operational requirement

REQ-DATA-001: Patient Data Storage

Priority: Critical

Description: The system shall store patient demographic information, medical history, visit notes, and clinical documentation.

Acceptance Criteria:

1. Structured data storage in PostgreSQL database
2. Unstructured document storage (PDFs, images) in AWS S3
3. Data retention for minimum 7 years per state requirements
4. Patient portal access to historical records **Compliance Standards:** HIPAA §164.312(a)(2)(iv), State medical records laws

REQ-AUDIT-001: Audit Logging

Priority: High

Description: The system shall maintain audit logs of user activities involving protected health information.

Acceptance Criteria:

1. Log user authentication events (login, logout, failed attempts)
2. Log access to patient records (viewing, creating, updating)
3. Log administrative configuration changes
4. Timestamp all audit events using UTC
5. Store audit logs for minimum 6 years **Compliance Standards:** HIPAA §164.312(b)

REQ-SEC-001: Data Encryption

Priority: Critical

Description: The system shall implement encryption to protect sensitive data.

Acceptance Criteria:

1. TLS 1.2 or higher for all HTTPS connections
2. Database connection encryption between application and database servers **Compliance Standards:** HIPAA §164.312(a)(2)(iv), §164.312(e)(1)

REQ-BACKUP-001: Data Backup

Priority: High

Description: The system shall perform regular backups of production data.

Acceptance Criteria:

1. Daily automated backups of database and file storage
2. Backup retention for 30 days
3. Backups stored in geographically separate AWS region **Compliance Standards:** HIPAA §164.308(a)(7)(ii)(A)

REQ-ACCESS-001: Emergency Access

Priority: Medium

Description: Clinical staff may need to access patient information in emergency situations.

Acceptance Criteria:

1. "Break glass" emergency access workflow documented in administrative procedures **Compliance Standards:** HIPAA §164.312(a)(2)(ii)

REQ-VENDOR-001: Third-Party Integrations

Priority: High

Description: The system shall integrate with third-party services including video infrastructure, EHR systems, pharmacy networks, and payment processors.

Acceptance Criteria:

1. API integrations with Twilio Video for video infrastructure
2. HL7 FHIR integration with major EHR vendors (Epic, Cerner)
3. Surescripts integration for e-prescribing
4. Stripe integration for payment processing **Compliance Standards:** HIPAA §164.308(b)

REQ-GEO-001: Provider Verification

Priority: High

Description: The system shall verify that healthcare providers have appropriate credentials and licenses.

Acceptance Criteria:

1. Providers upload copies of medical licenses during onboarding
2. DEA numbers verified for prescribing providers
3. Malpractice insurance certificates collected
4. Credentialing team reviews documentation before approval **Compliance Standards:** State Medical Practice Acts

REQ-LOC-001: Patient Location Tracking

Priority: Medium

Description: The system should identify patient location for clinical documentation purposes.

Acceptance Criteria:

1. Patients self-report their location during appointment booking **Compliance Standards:** State telemedicine laws

Non-Functional Requirements

Performance Requirements

- Page load times: <2 seconds for 95th percentile
- Video latency: <200ms end-to-end

- System availability: 99.9% uptime (excluding planned maintenance)
- Concurrent users: Support 10,000 simultaneous video sessions

Security Requirements

- Web Application Firewall (WAF) with OWASP Top 10 protection
- DDoS protection via AWS Shield
- Regular penetration testing (annual)
- Vulnerability scanning (weekly automated scans)
- Security incident response plan

Scalability Requirements

- Horizontal scaling of application servers based on load
- Auto-scaling for video infrastructure
- Database read replicas for geographic distribution
- CDN distribution for static assets

Usability Requirements

- WCAG 2.1 Level AA accessibility compliance
- Mobile-responsive design (iOS and Android browsers)
- Maximum 3 clicks to start video consultation from login
- Intuitive interface requiring no user training

Data Requirements

Data Collection

The system collects and processes the following categories of PHI:

- Patient demographics (name, DOB, address, phone, email)
- Insurance information
- Medical history and current medications
- Chief complaint and symptom information
- Clinical notes from provider encounters
- Prescription records
- Payment information

Data Retention

- Active patient records: Retained indefinitely while patient account is active
- Inactive accounts: 7 years after last encounter
- Audit logs: 6 years
- Billing records: 7 years per IRS requirements
- Video recordings: 7 years (if recorded)

Data Sharing

Patient data may be shared with:

- Healthcare providers participating in the network
- Pharmacy systems for prescription fulfillment
- Insurance companies for claims processing
- Third-party analytics for quality improvement

Regulatory Compliance Checklist

Requirement	Standard	Status	Notes
Encryption in transit	HIPAA §164.312(e)(1)	⚠️ Partial	TLS specified but video encryption not explicit
Encryption at rest	HIPAA §164.312(a)(2)(iv)	❌ Missing	No AES-256 or equivalent specified
Multi-factor authentication	HIPAA proposed rule	❌ Missing	Password-only authentication
Automatic logoff	HIPAA §164.312(a)(2)(iii)	❌ Missing	No session timeout specified
Audit controls	HIPAA §164.312(b)	⚠️ Partial	Logging present but review procedures missing
Contingency plan	HIPAA §164.308(a)(7)	⚠️ Partial	Backups exist but no disaster recovery plan
Emergency access	HIPAA §164.312(a)(2)(ii)	⚠️ Partial	Administrative only, no technical implementation
Business Associate Agreements	HIPAA §164.308(b)	❌ Missing	No BAA requirements specified
State license verification	State Medical Practice Acts	❌ Missing	No geographic license matching
Patient location verification	State Telemedicine Laws	❌ Missing	Self-reported location only
FDA device registration	21 CFR 882.5801	❌ Missing	Symptom assessment is likely Class II device
Risk analysis	HIPAA §164.308(a)(1)(ii)(A)	Not documented	Required but not referenced

Assumptions and Dependencies

Assumptions

- Healthcare providers maintain their own professional liability insurance
- Providers are responsible for maintaining active state licenses
- Patients have reliable internet connectivity for video consultations
- Third-party vendors (Twilio, Surescripts) maintain their own compliance certifications

Dependencies

- AWS infrastructure availability and performance
- Third-party video service (Twilio) reliability
- Surescripts network availability for e-prescribing

- State medical board databases for license verification (manual process)

Future Enhancements

Planned for Version 2.0

- Integration with wearable devices (blood pressure monitors, pulse oximeters)
- AI-powered clinical decision support for providers
- Patient mobile app (native iOS and Android)
- Multi-language support (Spanish, Mandarin)
- Integration with pharmacy delivery services

Under Consideration

- International expansion (Canada, UK)
- Specialty care consultations (dermatology, psychiatry)
- Group therapy sessions
- Remote patient monitoring programs

Document Approval:

This requirements document is approved for implementation with the understanding that compliance gaps identified in the regulatory checklist will be addressed through administrative procedures and future technical enhancements.

VIOLATION SUMMARY FOR TESTING: This document contains **12 major intentional violations** including:

1. Missing video encryption specification
2. No MFA requirement
3. Missing session timeout
4. Incomplete audit log review procedures
5. Missing disaster recovery plan
6. No emergency access technical implementation
7. Missing BAA requirements
8. No encryption at rest specification
9. Missing state license verification
10. Inadequate patient location verification
11. Unregistered FDA device (symptom assessment)
12. Missing minimum necessary controls

An AI compliance checker should detect 9-10 of these violations (75-85% detection rate), particularly the explicit missing requirements and FDA device classification issue.
